

SECCIÓN 2.4



Eventos, alertas e incidentes

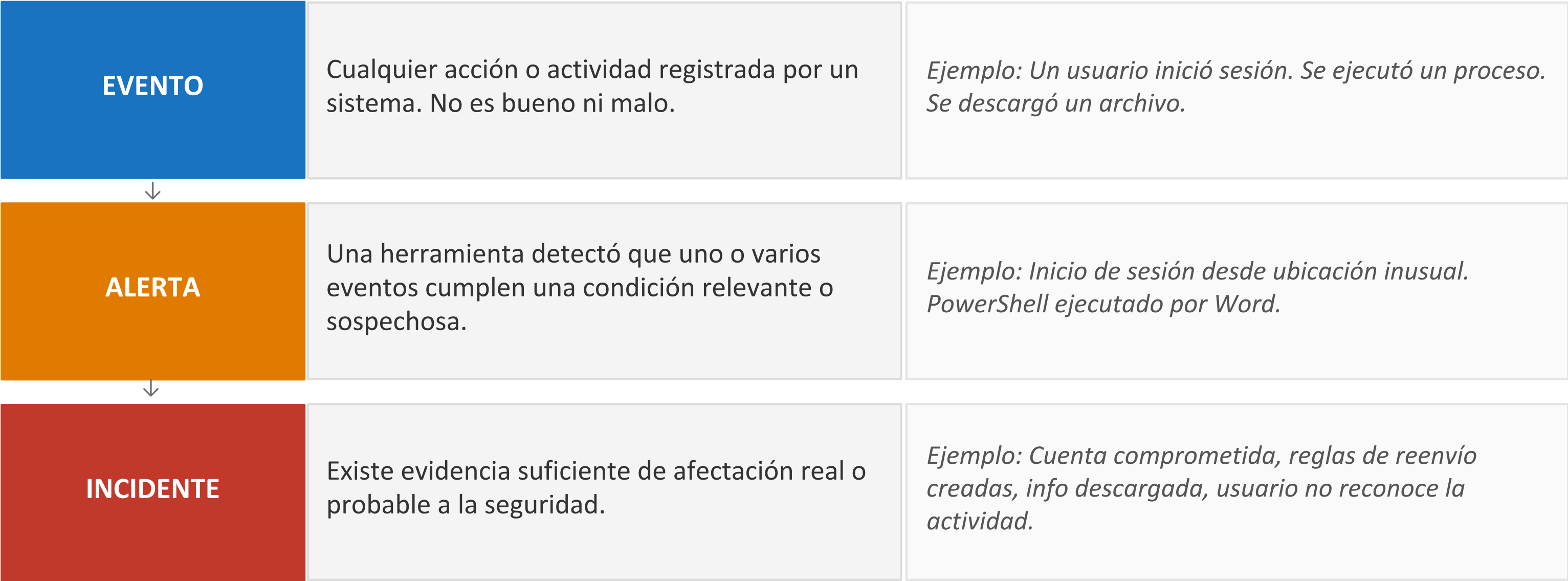
Temas de esta sección:

- Qué es un evento en ciberseguridad
- Qué es una alerta y cómo se genera
- Qué es un incidente y qué evidencia lo sostiene
- Diferencia práctica entre los tres conceptos
- Clasificación inicial: falso positivo, sospechoso, incidente probable
- Errores comunes: sobrerreaccionar y minimizar
- Ejemplos aplicados con alertas reales

2.4 | La progresión: Evento → Alerta → Incidente



En un SOC se generan miles de eventos por día. No todos son alertas. No todas las alertas son incidentes.



2.4 | Ejemplo comparativo: mismo login, tres clasificaciones distintas



Actividad base: User jperez — Login — Location: Brazil — MFA: Success — 09:15 AM

EVENTO	ALERTA	INCIDENTE
El usuario está de viaje por trabajo y suele conectarse desde esa ubicación. No hay actividad posterior sospechosa. Clasificación: actividad normal. No requiere acción.	La ubicación es inusual para ese usuario. La herramienta genera una alerta. Todavía no hay evidencia de abuso. Clasificación: requiere validación antes de cerrar.	Después del login, se crean reglas de reenvío, se descargan archivos sensibles y el usuario confirma que no reconoce la actividad. Clasificación: incidente probable. Escalar con evidencia.

El dato base puede ser el mismo. La clasificación cambia por el contexto y la evidencia adicional.



Durante el triage, el analista clasifica una alerta según la evidencia disponible:

Falso positivo	La alerta se generó por actividad legítima o condición esperada.	<i>PowerShell ejecutado por equipo de IT con ticket de cambio aprobado.</i>
Benigno confirmado	La actividad ocurrió, pero fue validada como autorizada.	<i>Descarga masiva por equipo de legales preparando auditoría programada.</i>
Sospechoso	Hay señales que requieren investigación adicional, pero no alcanza para confirmar incidente.	<i>Login desde IP inusual con MFA exitoso y sin actividad posterior visible aún.</i>
Incidente probable	La evidencia sugiere compromiso, pero requiere confirmación o respuesta.	<i>PowerShell desde Word + conexión externa + descarga de archivo + usuario sin rol técnico.</i>
Incidente confirmado	Evidencia suficiente de compromiso, impacto o violación de seguridad.	<i>Cifrado masivo de archivos + shadow copies eliminados + usuarios sin acceso.</i>

Lo importante: la clasificación debe estar respaldada por evidencia, no por intuición.



 SOBRERREACCIONAR

- ✗ "Hubo PowerShell → hay malware."
- ✗ "Hubo login desde otro país → cuenta comprometida."
- ✗ "Hubo descarga masiva → hubo exfiltración."
- ✗ "Hay IP sospechosa → equipo infectado."

 MINIMIZAR

- ✗ "Usó MFA → está todo bien."
- ✗ "Es IP interna → es seguro."
- ✗ "El EDR bloqueó → no hay más que revisar."
- ✗ "El usuario tiene permiso → el acceso es legítimo."

Sobrerreaccionar genera escalaciones innecesarias y fatiga en equipos L2/IR. Minimizar puede dejar pasar incidentes reales.

El analista debe validar antes de decidir. Ni asumir incidente sin evidencia, ni cerrar sin revisión suficiente.

2.4 | Buena vs mala documentación de una alerta



El valor del analista SOC no está solo en la decisión, sino en **cómo comunica y documenta lo que analizó.**

✗ Mala documentación:

"PowerShell sospechoso. Escalo."

✓ Buena documentación:

"Se observó ejecución de PowerShell iniciada por WINWORD.EXE con parámetros -nop -w hidden -enc, seguida de conexión HTTPS a dominio externo y descarga de archivo ejecutable en ruta de usuario (AppData\Roaming). Usuario rrhh.gomez no tiene rol técnico. La secuencia es compatible con ejecución inicial maliciosa (posible phishing con payload). Se recomienda escalamiento a IR/L2 para análisis forense del host."

La diferencia: la buena documentación explica qué se observó, qué evidencia lo respalda, por qué es relevante y qué acción se recomienda.